

Risk Assessment Report

ABC Healthcare Pvt. Ltd.

Cyber GRC Portfolio Case Study

Fictional case study created for learning and portfolio demonstration.

1. Introduction

Cybersecurity risks can affect an organization's data, systems, employees, and day-to-day operations. For a healthcare organization, protecting patient information is especially important because a security incident can affect both the organization and the people whose data it holds.

This risk assessment was prepared as a practical case study for ABC Healthcare Pvt. Ltd. The purpose was to identify common cybersecurity risks, understand their potential impact, and recommend suitable controls to reduce those risks.

2. Organization Overview

ABC Healthcare Pvt. Ltd. is a fictional healthcare organization that manages patient records, billing information, appointment data, and other patient-related documents.

The organization uses internal applications, email, employee endpoints, and cloud storage to manage and share information. Since these systems handle sensitive healthcare and business data, security risks such as unauthorized access, phishing, malware, cloud misconfiguration, and ransomware need to be considered.

3. Assessment Objective

- Identify important information assets.
- Identify relevant threats and vulnerabilities.
- Assess risks based on likelihood and impact.
- Determine an appropriate risk treatment approach.
- Recommend security controls to reduce identified risks.
- Document the assessment in a structured risk register.

4. Scope

This assessment focuses on selected risks related to:

- Patient personal data and medical records
- Patient documents
- Cloud-stored information
- Billing and appointment data
- Employee access to organizational systems
- Endpoint and backup security

Scope note: This assessment is a fictional portfolio case study and does not represent an actual assessment of ABC Healthcare Pvt. Ltd.

5. Risk Assessment Methodology

The assessment followed a simple qualitative risk assessment approach. Each identified risk was reviewed based on the asset involved, the possible threat, the vulnerability that could be exploited, and the potential impact on the organization.

1. Identify the Asset

The information, system, or business resource that could be affected was identified.

2. Identify the Threat

The potential event or actor that could cause harm was identified, such as phishing, malware, unauthorized access, cloud exposure, or ransomware.

3. Identify the Vulnerability

The weakness that could allow the threat to cause harm was identified, such as lack of MFA, excessive privileges, cloud misconfiguration, or unpatched systems.

4. Assess Likelihood

Likelihood was assessed as Low, Medium, or High using the scenario context, existing controls, exposure, recent suspicious activity, and known weaknesses.

5. Assess Impact

Impact was assessed based on possible effects on confidentiality, integrity, availability, operations, finances, regulatory obligations, and reputation.

6. Determine Risk Rating

Likelihood and impact were considered together to determine the overall risk level.

7. Select Risk Treatment

For the risks identified in this assessment, Mitigate was selected. Recommended controls were then identified to reduce likelihood or impact.

Methodology note: This case study uses qualitative ratings rather than numerical scoring. The ratings are based on the scenario information available and are intended for portfolio and learning purposes.

6. Risk Assessment Findings

R-01 - Malware Affecting Patient Personal Data

Scenario: Employees regularly use email, but security awareness training is not provided. The organization has recently received suspicious emails, creating a possibility that an employee could open a malicious attachment or link.

Asset: Patient Personal Data

Threat: Malware

Vulnerability: Lack of employee security awareness and training

Likelihood: The likelihood was rated High because employees have limited security awareness, suspicious emails have already been received, and email is regularly used. MFA is enabled, but it does not prevent every type of malware infection.

Impact: A malware incident could expose patient information and lead to loss of patient trust, reputational damage, financial consequences, and potential regulatory or legal issues.

Risk Rating: High

Treatment: Mitigate

Recommended Controls: Security Awareness Training; Endpoint Protection; Backup and Restore

Reasoning: Security awareness training can help employees recognize suspicious emails and attachments. Endpoint protection can detect and block malicious activity, while tested backups can help the organization recover if data or systems are affected.

R-02 - Excessive Access to Medical Records

Scenario: Employees use an internal application to access medical records. Some employees have access beyond what is required for their job responsibilities, and regular access reviews are not performed.

Asset: Medical Records

Threat: Insider Threat / Unauthorized Access

Vulnerability: Excessive user privileges and lack of regular access reviews

Likelihood: The likelihood was rated High because unnecessary access can remain active when user permissions are not regularly reviewed. This increases the possibility of unauthorized viewing or misuse of medical records.

Impact: Unauthorized access could result in patient data exposure, loss of trust, reputational damage, regulatory or legal consequences, and potential operational issues.

Risk Rating: High

Treatment: Mitigate

Recommended Controls: Role-Based Access Control (RBAC); Principle of Least Privilege; Periodic Access Reviews

Reasoning: Users should receive only the access required for their responsibilities. Regular access reviews can identify unnecessary or outdated permissions and help reduce the risk of unauthorized access.

R-03 - Phishing Leading to Patient Data Exposure

Scenario: Employees receive patient-related documents through email. Security awareness is limited, external websites can be accessed through email links, MFA is not enabled for the internal application, and suspicious phishing emails have recently been received.

Asset: Patient Documents

Threat: Phishing / External Attacker

Vulnerability: No MFA and limited phishing awareness

Likelihood: The likelihood was rated High because employees have limited phishing awareness, MFA is not enabled, and suspicious phishing emails have already been observed.

Impact: A successful phishing attack could result in account compromise and unauthorized access to patient documents, potentially causing data leakage, financial loss, reputational damage, and operational disruption.

Risk Rating: High

Treatment: Mitigate

Recommended Controls: Multi-Factor Authentication (MFA); Security Awareness Training; Email Security / Phishing Protection; Endpoint Protection

Reasoning: MFA provides an additional layer of protection if credentials are stolen. Awareness training helps employees identify phishing attempts, while email and endpoint security controls can detect and block malicious activity.

R-04 - Cloud Storage Misconfiguration

Scenario: Patient documents are stored in cloud storage. Due to incorrect access settings, some files are publicly accessible. The organization does not have a proper process for regularly reviewing cloud configurations. MFA is enabled for administrator accounts.

Asset: Patient Documents in Cloud

Threat: Unauthorized Access / Data Exposure

Vulnerability: Cloud storage misconfiguration and lack of regular configuration reviews

Likelihood: The likelihood was rated High because some files are already publicly accessible and cloud configurations are not regularly reviewed. MFA protects administrator account access, but it does not prevent exposure caused by incorrectly configured public permissions.

Impact: Exposure of patient documents could result in a data breach, privacy violations, regulatory or legal consequences, financial loss, reputational damage, and loss of patient trust.

Risk Rating: High

Treatment: Mitigate

Recommended Controls: Public Access Restrictions; Principle of Least Privilege; Cloud Configuration Monitoring and Reviews

Reasoning: Public access should be restricted unless it is specifically required. Least-privilege access can reduce unnecessary permissions, while regular configuration monitoring can help identify and correct insecure cloud settings.

R-05 - Ransomware Affecting Critical Systems

Scenario: Critical systems store patient records, billing information, and appointment data. Employees can download files from the internet, some systems are not regularly updated, and although backups exist, restoration is not tested regularly. Recent ransomware activity has also been observed in the

healthcare sector.

Asset: Patient Records and Billing Data

Threat: Ransomware

Vulnerability: Unpatched systems, internet-based file downloads, and untested backups

Likelihood: The likelihood was rated High because some systems are not regularly patched, employees can download files from the internet, and ransomware is an active threat. The untested backups mainly increase the difficulty of recovery rather than directly increasing the likelihood of an attack.

Impact: A successful ransomware attack could make patient records, billing, and appointment systems unavailable. This could disrupt healthcare operations, cause financial losses, affect patient services, and create significant recovery challenges.

Risk Rating: High

Treatment: Mitigate

Recommended Controls: Regular Patch Management; Endpoint Detection and Response (EDR); Web Filtering; Tested Backup and Restore Procedures

Reasoning: Regular patching reduces exposure to known vulnerabilities. EDR and web filtering can help detect or prevent malicious activity. Regularly tested backups ensure that the organization can actually restore critical systems and data when required.

7. Overall Risk Summary

The assessment identified five key cybersecurity risks affecting patient information, medical records, cloud-stored documents, and critical business systems.

All five risks were assessed as High based on the likelihood and impact described in each scenario. The assessment identified different risk areas, including malware, unauthorized access, phishing, cloud misconfiguration, and ransomware.

The risks mainly affect three important areas of information security:

- Confidentiality: Unauthorized access or exposure of patient and medical information.
- Integrity: Unauthorized modification, deletion, or compromise of organizational data.
- Availability: Loss of access to critical systems and information, particularly in a ransomware scenario.

The recommended approach for all five risks is Mitigate. The proposed controls focus on reducing the likelihood of security incidents and limiting their impact if an incident occurs.

8. Conclusion

This risk assessment demonstrates how a basic qualitative risk assessment can be used to identify and prioritize cybersecurity risks within an organization.

The assessment showed that security risks are not always caused by a single weakness. For example, phishing risk can increase when employees have limited security awareness and MFA is not enabled, while cloud data exposure can occur because of incorrect access configurations even when administrator accounts are protected with MFA.

The recommended controls therefore focus on a combination of people, processes, and technology, including security awareness training, access controls, MFA, patch management, endpoint protection, cloud configuration monitoring, and tested backup procedures.

This case study also highlights the importance of regularly reviewing risks and security controls as the organization's systems, users, and threat environment change.

Portfolio Note: This is a fictional case study created for learning and demonstration of Cyber GRC risk assessment concepts. It is not an assessment of a real organization.